

Clase 101 — Fallos de autenticación y bypass

Parte: 4 — Seguridad de aplicaciones web · Fuente: *The Web Application Hacker's Handbook (Stuttard & Pinto)* 🕒 Duración estimada: 120 min · Nivel: Avanzado

Objetivo

Auditar los mecanismos de **autenticación** y descubrir formas de saltárselos: enumeración de usuarios, fuerza bruta, fallos en recuperación de contraseña, MFA débil y lógica de login rota. La autenticación es la puerta de la aplicación; romperla suele ser el hallazgo de mayor impacto.

⚠️ **Ética:** solo en labs propios/autorizados. La fuerza bruta y el bypass sobre cuentas ajenas son delitos.

Resultados de aprendizaje

Al finalizar, el alumno podrá:

- 1. **Detectar** enumeración de usuarios por diferencias en respuestas/tiempos.
- 2. **Ejecutar** fuerza bruta controlada y credential stuffing en un lab.
- 3. **Explotar** fallos en flujos de recuperación de contraseña.
- 4. **Evaluar** la robustez de la MFA y sus bypass comunes.
- 5. **Recomendar** controles: rate limiting, MFA correcta, mensajes genéricos.

Temas

#	Tema	Por qué importa
1	Enumeración de usuarios	Primer paso del ataque
2	Fuerza bruta y stuffing	Ataque directo a credenciales
3	Rate limiting y su evasión	Defensa clave y sus grietas
4	Recuperación de contraseña	Flujo frecuentemente roto
5	MFA: tipos y bypass	Segunda barrera, no infalible
6	Lógica de login rota	Bypass sin adivinar credenciales
7	Defensa en profundidad	Cierre del fallo

Definiciones y características

- **Enumeración de usuarios:** determinar qué cuentas existen por diferencias en las respuestas. Característica: habilita ataques dirigidos.

- **Credential stuffing:** probar credenciales filtradas de otras brechas. Característica: explota la reutilización de contraseñas.
- **Rate limiting:** límite de intentos por tiempo/IP. Característica: defensa esencial contra fuerza bruta.
- **MFA (autenticación multifactor):** segundo factor además de la contraseña. Característica: reduce el riesgo pero tiene bypass conocidos.
- **Token de reset:** valor temporal para recuperar contraseña. Característica: si es predecible o no expira, es explotable.
- **Response timing:** diferencias de tiempo que filtran información. Característica: canal lateral de enumeración.

Herramientas y preparación

- **PortSwigger labs** de autenticación y **DVWA**.
- **Burp Intruder** para fuerza bruta y enumeración.
- Listas de usuarios/contraseñas de SecLists.

Laboratorio guiado

 Solo en labs propios.

1. Prueba el login con un usuario inexistente y otro existente; compara mensajes y tiempos (enumeración).
2. Con Intruder, enumera usuarios válidos por diferencia de respuesta.
3. Ejecuta fuerza bruta de contraseña sobre un usuario válido en un lab sin rate limiting.
4. Analiza el flujo de **recuperación de contraseña**: ¿el token es predecible?, ¿expira?, ¿se puede reusar?
5. Prueba un **bypass de MFA**: reenviar la petición sin el paso 2, reutilizar código, o forzar el código (si no hay límite).
6. Busca lógica rota: acceder a `/account` con un estado de sesión parcial.
7. Documenta cada debilidad con evidencia y su corrección.

Ejercicios

1. Detecta enumeración de usuarios por mensaje y por tiempo, por separado.
2. Diseña un ataque de credential stuffing y explica su defensa (MFA, detección de reuso).
3. Analiza un token de reset y evalúa su entropía y expiración.
4. Enumera 4 bypass de MFA reales y cómo prevenirlos.
5. Explica por qué los mensajes de error deben ser genéricos.
6. Diseña una política de rate limiting sensata (por cuenta y por IP).

Reto verificable

Resuelve un lab de PortSwigger que combine **enumeración de usuarios + fuerza bruta** y accede a la cuenta objetivo, o un lab de **bypass de MFA**. **Criterio de aceptación:** el lab queda resuelto, documentas la señal que reveló el usuario válido (o el fallo de MFA), la credencial/técnica y los controles que lo habrían evitado.

Errores comunes

Síntoma / mensaje	Causa y cómo arreglar
Bloqueo tras pocos intentos	Rate limiting; rota IPs (en lab) o busca otro vector
Mensajes idénticos siempre	Sin enumeración por mensaje; prueba por tiempo
Token de reset aleatorio	Bien diseñado; busca reuso o falta de expiración
MFA no bypassable	Implementación correcta; documenta como fortaleza
Fuerza bruta sin éxito	Contraseña fuerte; prueba stuffing con listas reales

Preguntas frecuentes

 **¿La MFA elimina la fuerza bruta?** Reduce mucho el riesgo, pero un segundo factor mal implementado (sin límite, reusable) puede saltarse.

 **¿Por qué importan los tiempos de respuesta?** Porque una diferencia consistente entre usuario válido e inválido filtra información aunque los mensajes sean iguales.

 **¿Bloquear la cuenta es buena defensa?** Puede provocar denegación de servicio. Mejor combinar rate limiting, MFA y detección de anomalías.

Referencias

- Stuttard & Pinto, *The Web Application Hacker's Handbook*, cap. 6.
- OWASP Authentication Cheat Sheet.
- OWASP WSTG — Authentication Testing.
- PortSwigger Authentication: <https://portswigger.net/web-security/authentication>

Siguiente clase

Clase 102 - Gestion de sesiones y ataques asociados